

Cybersecurity Incident Report

Brute Force Attack & Malicious Redirect

Analyst: Mohammad

Tool used: tcpdump (packet capture), sandbox environment

Affected system: yummyrecipesforme.com web host and admin panel

Section 1: Network Protocol Identified

The tcpdump log captured during the investigation identifies two protocols involved in establishing the connection between the user and the website:

DNS (Domain Name System) — the browser queries dns.google for the IP address of yummyrecipesforme.com, and later for greatrecipesforme.com, receiving an A record response for each.

HTTP (Hypertext Transfer Protocol) — following a standard TCP three-way handshake (SYN, SYN-ACK, ACK), the browser issues a GET / HTTP/1.1 request to load the webpage, for both domains observed in the log.

Section 2: Incident Documentation

Source of evidence:

tcpdump packet capture log; senior analyst's review of the website's source code; customer reports submitted to the company helpdesk.

Summary of events:

A former employee gained unauthorized access to the yummyrecipesforme.com web host's administrative panel. The administrative account's password had not been changed from its original default value. The former employee performed a brute force attack, repeatedly submitting known default passwords for the administrative account until access was obtained.

After gaining access, the former employee modified the website's source code, embedding a JavaScript function that prompted visitors to download and run an executable file upon loading the webpage. The former employee then changed the administrative account's password, preventing the legitimate website owner from logging in to the admin panel.

Several hours after the modification was made, multiple customers contacted the company's helpdesk, reporting that the website had prompted them to download a file in order to access free recipes. Customers reported that after running the downloaded file, their browser's address changed and their computers began operating more slowly.

The website owner attempted to log in to the admin panel and was unable to do so, and subsequently contacted the website hosting provider. A cybersecurity analyst team was assigned to investigate.

Sandbox investigation — packet capture sequence:

1. A DNS request was made for yummyrecipesforme.com, resolving to IP 203.0.113.22.
2. A TCP connection was established (SYN, SYN-ACK, ACK), followed by an HTTP GET request that loaded the webpage.
3. The page prompted a download of an executable file. The file was downloaded and executed.
4. A new DNS request was made for greatrecipesforme.com, resolving to IP 192.0.2.17.

5. A new TCP connection and HTTP GET request followed, confirming the browser had been redirected to this second domain.

A senior analyst reviewed the website's source code directly and confirmed the presence of injected JavaScript prompting the file download. Analysis of the downloaded file identified a script responsible for redirecting visitors' browsers from yummyrecipesforme.com to greatrecipesforme.com, a fraudulent site hosting malware.

The cybersecurity team determined that the web server had been compromised via a brute force attack, made possible because the administrative account's password remained set to its default value, and because no controls were in place to limit or detect repeated failed login attempts.

Section 3: Recommended Security Measure

Recommendation: Require strong, unique passwords for all administrative accounts (and prohibit the use of default credentials).

This measure directly addresses the root cause identified in this incident: the administrative account password was never changed from its default value, which made it guessable through a basic brute force attack using a list of commonly known default credentials. Enforcing a password policy that requires administrators to set a strong, unique password immediately upon account creation — and disallowing default or previously-used passwords — would have prevented the attacker from gaining access in the first place, regardless of how many attempts were made.

While other measures such as two-factor authentication or login attempt limiting add valuable additional layers of defense, they would only have made this specific attack harder to execute. A strong password policy eliminates the specific vulnerability that was actually exploited in this incident.